Contents

Volume 03 — Web Attacks, IDS, Assurance, Malware (L19–L27) **1**
L19: Command Injection, LFI/RFI & Server-Side Attacks 1
L20: Session Management, CSRF & Authentication Flaws 2
L21: Intrusion Detection with Snort 2
L22: IDS Tuning, IPS Mode & Log Analysis 3
L23: Vulnerability Scanning with OpenVAS/GVM 3
L24: CVSS Scoring & Vulnerability Prioritization 4
L25: Security Assurance — Frameworks, Audits & Compliance 4
L26: Malware Taxonomy & Static Analysis 5
L27: Dynamic Malware Analysis & Sandboxing 5

Volume 03 — Web Attacks, IDS, Assurance, Malware (L19–L27)

> Cyber Security Tools · IGNOU/BAOU nou26_ge86 · Prof. Dr. Nilesh K. Modi
> **notes-3** — concept exam notes (what things are / what they do). Condensed from course `pdf/` volumes. No lab command dumps.

Server-side flaws, session/CSRF, Snort/IDS, OpenVAS, CVSS, frameworks, malware analysis roles.

L19: Command Injection, LFI/RFI & Server-Side Attacks

What it is / what it does

- Server-side injection flaws let attackers execute OS commands or include arbitrary files.

Defenses (one-liners)

- Never pass user input to shell (exec, system).
- Use allowlists for file paths.
- Disable allow_url_include in PHP.
- Run web server as low-privilege user; chroot/containers.

Exam lines

- Server-side injection flaws let attackers execute OS commands or include arbitrary files.

L20: Session Management, CSRF & Authentication Flaws

What it is / what it does

- Weak session handling and missing CSRF tokens enable account takeover and unauthorized actions.
- **Testing steps** — Check cookie flags: Secure, HttpOnly, SameSite.
- Test session fixation: login without accepting new session ID.
- CSRF: create HTML form posting to state-changing endpoint.
- Test password reset flow for token predictability.

Defenses (one-liners)

- Generate cryptographically random session IDs.
- Rotate session ID on login.
- Implement CSRF tokens on all state-changing requests.
- Enforce MFA for sensitive operations.
- Set SameSite=Strict or Lax on cookies.

Exam lines

- Weak session handling and missing CSRF tokens enable account takeover and unauthorized actions.
- **Testing steps** — Check cookie flags: Secure, HttpOnly, SameSite.
- Test session fixation: login without accepting new session ID.
- CSRF: create HTML form posting to state-changing endpoint.
- Test password reset flow for token predictability.

L21: Intrusion Detection with Snort

What it is / what it does

- Snort is an open-source network IDS/IPS that matches traffic against rule-based signatures.

Defenses (one-liners)

- Fragmentation, encoding, encryption bypass signature IDS.
- Defenders: combine Snort with anomaly detection, TLS inspection (where legal).
- Keep rules updated: sudo snort-update / PulledPork.
- Tune rules to reduce false positives.

Exam lines

- Snort is an open-source network IDS/IPS that matches traffic against rule-based signatures.

L22: IDS Tuning, IPS Mode & Log Analysis

What it is / what it does

- Operationalize IDS — reduce false positives, enable inline blocking, correlate alerts.
- **Tuning steps** — Baseline normal traffic for 48 hours.
- Suppress noisy rules (e.g., ICMP ping).
- Create custom rules for critical assets.
- Integrate with SIEM (Splunk, ELK, Wazuh).
- Define escalation playbooks per alert category.

Defenses (one-liners)

- Defense: encrypted C2 is hard to signature-detect — use behavioral analytics.
- Regular purple-team exercises to validate detection coverage.
- Document every suppressed rule with justification.

Exam lines

- Operationalize IDS — reduce false positives, enable inline blocking, correlate alerts.
- **Tuning steps** — Baseline normal traffic for 48 hours.
- Suppress noisy rules (e.g., ICMP ping).
- Create custom rules for critical assets.
- Integrate with SIEM (Splunk, ELK, Wazuh).

L23: Vulnerability Scanning with OpenVAS/GVM

What it is / what it does

- OpenVAS (Greenbone Vulnerability Manager) performs authenticated and unauthenticated network vulnerability scans.

Defenses (one-liners)

- Patch or mitigate every Critical/High finding.
- Schedule monthly scans; continuous with Greenbone Enterprise.
- Use credentialed scans for accurate patch status.
- Validate fixes with re-scan.

Exam lines

- OpenVAS (Greenbone Vulnerability Manager) performs authenticated and unauthenticated network vulnerability scans.

L24: CVSS Scoring & Vulnerability Prioritization

What it is / what it does

- Common Vulnerability Scoring System (CVSS) provides standardized severity ratings for triage.
- **Base:** Attack Vector, Complexity, Privileges, User Interaction, Scope, Impact (C/I/A)
- **Temporal:** Exploit maturity, remediation level
- **Environmental:** asset-specific modifiers

Defenses (one-liners)

- Don't chase volume — prioritize by exploitability + asset value.
- Track mean time to remediate (MTTR) by severity.
- Integrate CVSS with ticketing (Jira, ServiceNow).

Exam lines

- Common Vulnerability Scoring System (CVSS) provides standardized severity ratings for triage.
- **Base:** Attack Vector, Complexity, Privileges, User Interaction, Scope, Impact (C/I/A)
- **Temporal:** Exploit maturity, remediation level
- **Environmental:** asset-specific modifiers

L25: Security Assurance — Frameworks, Audits & Compliance

What it is / what it does

- Assurance demonstrates that controls are designed and operating effectively — PGDCS-103 Block 2, Unit 1.
- **Key frameworks:**

Framework	Focus
ISO 27001	ISMS certification
NIST CSF	Identify, Protect, Detect, Respond, Recover
CIS Controls	Prioritized technical safeguards
COBIT	IT governance

Defenses (one-liners)

- Maintain evidence repository (policy version control).
- Automate compliance checks (InSpec, OpenSCAP).
- Annual external audit for certification.
- Reference Nina Godbole Ch. on metrics and frameworks.

Exam lines

- Assurance demonstrates that controls are designed and operating effectively
- **Key frameworks:**

L26: Malware Taxonomy & Static Analysis

What it is / what it does

- Classify malware and examine binaries without execution — PGDCS-103 Block 2, Unit 2.
- **Malware types** — Virus, worm, trojan, ransomware, rootkit, spyware, adware, fileless malware.

Defenses (one-liners)

- Block known hashes at endpoint (EDR).
- Application allowlisting.
- Email attachment sandboxing.
- User awareness — don’t open unknown attachments.

Exam lines

- Classify malware and examine binaries without execution
- **Malware types** — Virus, worm, trojan, ransomware, rootkit, spyware, adware, fileless malware.

L27: Dynamic Malware Analysis & Sandboxing

What it is / what it does

- Execute malware in isolated environment to observe behavior — network callbacks, file changes, registry keys.
- **Cuckoo Sandbox** — automated analysis
- **ANY.RUN** — interactive cloud sandbox
- **Procmon + Wireshark** — manual analysis

Defenses (one-liners)

- Block C2 domains at DNS/firewall (threat intel feeds).
- Behavioral detection (AMS/EDR).
- Network segmentation limits lateral spread.
- Report IOCs to CERT-In for national coordination.

Exam lines

- Execute malware in isolated environment to observe behavior — network callbacks, file changes, registry keys.
- **Cuckoo Sandbox** — automated analysis
- **ANY.RUN** — interactive cloud sandbox
- **Procmon + Wireshark** — manual analysis